ECE 443 / 518: Introduction to Computer Cyber Security

Project 3: Security in the Wild
Technical Analysis of the Anker Eufy Security Camera Vulnerabilities

Student Name: Shashwat Choudhry
Student CWID: A20507277
Course: ECE 443 / 518 Computer Cyber Security (Fall 2026)
Topic Selection: Anker Eufy Security Camera Incident: Technical Security and Privacy Analysis
Report Due Date: November 01, 2026
Word Count Verification: 1232 Words (Target: 1,200 Words)

1. Threat Model and Security Policy

Home security cameras operate inside intimate spaces, recording video and audio. Modern smart cameras also process facial crops, biometric feature vectors, authentication tokens, and hardware identifiers like serial numbers and MAC addresses. Protecting these assets is a primary engineering requirement.

A proper security policy for residential surveillance requires five core properties:
1. Confidentiality: Live and stored footage must remain accessible exclusively to authenticated account holders.
2. Integrity: Video streams, control commands, and metadata must resist in-transit tampering and frame injection.
3. User Sovereignty: No visual data or telemetry may leave local hardware without explicit user permission.
4. Cryptographic Rigor: Dynamic, per-session encryption keys must protect all transmissions, anchored in local hardware security modules.
5. Verifiable Erasure: User deletion requests must trigger irreversible cryptographic removal across physical and cloud storage tiers.

The threat model accounts for three distinct adversaries:
First, external remote attackers on the Internet targeting exposed web services, media ports, and predictable cloud storage buckets.
Second, local network eavesdroppers intercepting unencrypted wireless packets over Wi-Fi or transit paths.
Third, cloud insider threats, including company personnel, third-party operators, or attackers who breach centralized cloud infrastructure.

Eufy centered its marketing on absolute privacy, promising that video footage stayed strictly local and never reached external servers without permission. Users trusted that the cameras guarding their homes would not become surveillance backdoors. The actual technical implementation contradicted every one of these promises.

2. Technical Breakdown of Security Flaws

The fundamental flaw in Eufy's system was architectural misrepresentation. While advertising local on-device storage, cameras uploaded facial recognition crops, full thumbnails, and metadata to Amazon Web Services servers whenever motion occurred. These uploads occurred even when users

disabled cloud features and opted out of cloud processing. Facial recognition data persisted on AWS after users deleted recordings, and profiles were correlated across accounts without disclosure.

The most critical vulnerability was unencrypted video streaming accessible through open cloud endpoints. Independent researchers discovered that anyone could stream live video from customer cameras using standard media software like VLC Player. The exploit chain operated through four steps:
1. A user authenticated to the Eufy web portal.
2. By enabling browser developer tools in debug mode, the client exposed internal API calls requesting cloud relay streams.
3. The server returned a plaintext streaming URL linking to Eufy's cloud media servers.
4. This URL could be copied directly into VLC Player, initiating an unencrypted live video feed without requiring further credentials.

The structure of the streaming URL was fundamentally insecure. It contained the camera serial number encoded in standard Base64, an epoch timestamp, an MD5 token, and a static hexadecimal signature. Because Base64 is fully reversible, anyone with access to the serial number could derive the endpoint. Serial numbers were printed directly on retail boxes and camera bodies, allowing opportunistic attackers to target discarded packaging. Furthermore, because serial numbers followed predictable patterns, attackers could automate enumeration across customer ranges. The media server never validated timestamp freshness, meaning expired timestamps were accepted without rejection.

When Eufy applied encryption, researchers decompiled camera firmware and extracted a shared, hardcoded symmetric key: 'ZXSecurity17Cam@'. Every camera across the product line used this identical 16-byte key for AES-128 encryption. The cipher ran in Electronic Codebook mode without dynamic initialization vectors, producing identical ciphertext blocks for identical inputs and leaking image structures. This static key had been visible in public configuration files since 2019, exposing thousands of households for years.

Finally, Eufy failed basic data governance standards. Deleting video clips from the mobile app left thumbnail images and facial crops intact on AWS S3 buckets. Users could access cloud-stored images even after powering off the base station, and data remained reachable following complete account deletion. This violated core privacy principles and contravened European Union GDPR mandates regarding the right to erasure.

3. Evaluation of Remediation, Emerging Threats, and Improvements

When security researchers presented proof of unencrypted streaming, Anker publicly denied that VLC playback was possible. Only after major technology publications replicated the exploit across multiple states did Anker acknowledge the flaws and issue patches.

Eufy rolled out several technical fixes to resolve the disclosed vulnerabilities:
1. Debug mode and verbose API logging were stripped from the production web portal.
2. Plaintext streaming links were disabled, and video delivery was migrated to WebRTC with mandatory Datagram Transport Layer Security and Secure Real-time Transport Protocol encryption.
3. The hardcoded key 'ZXSecurity17Cam@' was retired in favor of dynamic session key exchanges.
4. Mobile applications were updated to inform users that push notification thumbnails require cloud transit unless text-only mode is selected.

While these measures closed the VLC exploit, significant threats remain. WebRTC relies on central signaling servers. An adversary observing signaling metadata can map network addresses, monitor connection intervals, and infer when occupants are home. Additionally, because Eufy manages the

signaling servers, users remain vulnerable to cloud insider attacks where unauthorized public keys could be injected during signaling negotiations. The system also remains dependent on closed, proprietary firmware updates that cannot be audited by the user.

To build a genuinely secure camera system, several technical improvements are required:
First, implement client-side zero-knowledge encryption where video feeds are encrypted using public keys held exclusively on the user's mobile device, preventing cloud servers from viewing raw video.
Second, generate distinct cryptographic keys on-device using a hardware security module, eliminating shared firmware secrets.
Third, enforce mutual TLS authentication and certificate pinning between the camera and authorized clients to block proxy interception.
Fourth, establish true local network independence, allowing users to stream video directly over a local area network through authenticated local RTSP without external cloud dependencies.
Fifth, maintain an active third-party audit schedule and a public bug bounty program to identify and remediate vulnerabilities before commercial release.

4. Conclusion

The Eufy security camera incident illustrates the severe risks created when marketing claims diverge from engineering reality. Eufy promised private, on-device storage while secretly routing unencrypted video, facial crops, and biometric data through cloud servers. The failure combined broken access controls, trivial hardcoded cryptography, and irresponsible data retention policies. While emergency patches fixed the immediate streaming loophole, the incident damaged customer trust and demonstrated that proprietary IoT systems require constant external scrutiny. Authentic consumer security requires transparent system architecture, independent audits, and cryptographic enforcement rather than unverified corporate promises.

5. References

[1] S. Hollister, "Anker's Eufy lied to us about the security of its security cameras," The Verge, Nov. 30, 2022.
[2] P. Moore, "Eufy Security Camera Privacy and Authentication Flaws," Vulnerability Disclosure, Nov. 2022.
[3] A. Al-Fuqaha et al., "Internet of Things: A survey on enabling technologies, protocols, and applications," IEEE Communications Surveys and Tutorials, vol. 17, no. 4, pp. 2347-2376, 2015.
[4] R. Morabito, "CoAP vs. MQTT vs. HTTP: Evaluation of mobile IoT application protocols," IEEE Pervasive Computing, vol. 16, no. 4, pp. 58-66, 2017.
[5] SEC Consult Vulnerability Lab, "Static Cryptographic Material in IoT Gateway Configuration Files," Security Advisory, 2022.
[6] European Union, "Regulation (EU) 2016/679 (General Data Protection Regulation)," Official Journal of the EU, 2016.
[7] C. Johnston, "Eufy cameras found streaming unencrypted video to cloud," Ars Technica, Dec. 2022.